

Day 30: Enterprise Security Hardening

Until now: "Can I see what happened?"

Today: "How do I reduce the chance that something bad can happen in the first place?"

Distinction: Visibility/Detection | Hardening/Prevention

By the end:

- ☐ Understand security hardening
- ☐ Understand a security baseline
- ☐ Understand attack surface
- ☐ Understand configuration drift
- ☐ Perform your first structured security assessment
- ☐ Review privileged AD membership
- ☐ Evaluate the domain password/lockout posture
- ☐ Evaluate Windows Firewall posture
- ☐ Evaluate SMB security
- ☐ Identify weaknesses before changing anything
- ☐ Implement justified hardening changes
- ☐ Verify that security changes didn't break business functionality
- ☐ Understand basic change-control thinking
- ☐ Begin actual Security+ studying

Tiny Retention Check:

4624: Successful authentication.

4625: Failed authentication.

4688: Process Creation.

4104: PowerShell Script Block Logging

If Administrator adds Bob to Domain Admins, who is the actor and who is the target?

Actor: Administrator, Target: Bob

Difference between detection and prevention? TO BE COVERED!

New Concept: Hardening

Imagine Bear Corp installs amazing logging. They record: every login, every PowerShell command, every process, and every account change. But suppose they have: unnecessary administrators, weak authentication policy, legacy protocols, unnecessary services, permissive firewall rules, insecure SMB configuration. They have excellent visibility into an unnecessarily vulnerable environment.

Hardening means reducing weaknesses and unnecessary attack opportunities through secure configuration.

Think: Default / functional system -> Assess exposure -> Remove unnecessary capability -> Restrict access -> Strengthen configuration -> Validate -> Hardened system

The attack surface is the collection of ways an attacker might interact with or compromise a system. Things like: exposed services, protocols, accounts, admin privileges, applications, network ports, credentials, remote-management paths. More functionality frequently creates more things that must be secured.

Security baseline: Instead of every administrator inventing their own idea of “secure,” organizations can use defined baselines.

Conceptually: Expected secure configuration versus Actual configuration. The difference gives you things to assess. Microsoft’s current guidance describes a security baseline as a collection of recommended configuration settings and the security implication of those settings.

Configuration drift:

Imagine Monday: Firewall = enabled, SMBv1 = disabled, Only authorized admins = privileged

Six months later: Firewall exception added, Temporary admin never removed, Legacy protocol enabled for troubleshooting

The system drifted away from its intended configuration. Professional security doesn’t stop at: “We hardened it once.”

Build Your Assessment Sheet

Control	Current State	Desired State	Risk	Action	Verified
Privileged Membership					
Password / Lockout					
Windows Firewall					
SMB Security					

Security Assessment #1

Area A: Privileged Access

Scenario: You’re given kevinlab.local as a new security analyst. First question: Who has powerful privileges in this domain?

Find and inspect groups such as: Domain Admins, Enterprise Admins, Schema Admins, Administrators.

Domain Admins: Members = Administrator, Member Of = Administrators and Denied RODC Password Replication

Enterprise Admins: Members = Administrator, Member Of = Administrators and Denied RODC Password Replication

Schema Admins: Members = Administrator, Member of = Denied RODC Password Replication

Administrators: Description is *"complete and unrestricted access to the computer/domain"*,

Members = Administrator, Domain Admins, and Enterprise Admins

Job: Determine:

1. Who is currently in each?
 - a. **Read above for answer.**
2. Why is each group powerful?
 - a. **Domain Admins is powerful because they have power over the entire domain. For enterprise admins, it is access over the entire forest. For Schema Admins, they have power over the AD schema. Administrators groups have power over everything.**
3. Does each member appear necessary?
 - a. **Yes, it only has the default Administrator account.**
4. Which account do you normally use administratively?
 - a. **KEVINLAB\Administrator**
5. Would ordinary HR/Finance/Sales users ever belong there?
 - a. **No. They should never have control over an entire domain.**

Concepts:

Least Privilege: An identity receives only the privileges necessary to perform its job

Privilege Separation: Your everyday identity and administrative identity ideally aren't treated as interchangeable. Think about why an organization might want: Kevin's ordinary account not equal to Kevin's administrative account.

Security Assessment #2

Domain Password + Lockout Policy

Ask: What authentication rules apply to domain users?

Find your domain's current password/account-lockout policy.

Discover:

- Minimum password length: **7 characters**
 - **Helps against brute force and dictionary attacks, shorter lengths increase guessability, very hard to remember if the length is too long**

- Complexity Requirements: **Enabled**
 - **Reduce weak, predictable passwords with different characters and special types**
- Password History: **Enforced, Keep password history for 24 passwords remembered**
 - **This means a user can't use any of their last 24 passwords.**
 - **Using the same passwords across accounts, password recycling**
- Minimum / maximum age: **1 day minimum and 42 days maximum**
 - **Constantly changing passwords to remain unpredictable, if changing too often it might be hard to remember the password**
- Lockout threshold: **0 invalid, so it won't lock out**
 - **Prevent brute force, if the lockout is like 1 or 2....that might be bad for mistypes**
- Lockout duration: **Not defined**
 - **Prevent brute force**
- Reset counter: **Not defined**

For each setting, ask: What account or behavior is this attempting to address?
 Could an extremely aggressive lockout threshold itself create a problem?

Security Assessment #3

Windows Firewall, Assessing both SRV-DC01 and CLIENT01

Questions:

1. What firewall profiles exist?
 - a. **SRV-DC01: Domain Profile, Private Profile, Public Profile**
 - b. **CLIENT01: Same as SRV-DC01.**
2. Which profile is currently active?
 - a. **SRV-DC01: Public Profile is Active**
 - b. **CLIENT01: Domain Profile is Active.**
3. Is the firewall enabled?
 - a. **SRV-DC01: Yes.**
 - b. **CLIENT01: Yes.**
4. What's the difference between inbound and outbound rules?
 - a. **Inbound is incoming traffic into the network**
 - b. **Outbound is what the machine is allowed to initiate going out**
5. Why might disabling Windows Firewall entirely be a bad troubleshooting habit?
 - a. **Personal Experience: People can scan your network and ports by disabling it. No guard bells. You expose everything to the listening service at once.**

Self-note: Private less restrictive: home or office networks, while public is for public networks like the airport etc

Security Assessment #4

SMB Security: relating to the file shares we built. (\\SRV-DC01\HR as example)

Determine:

1. Is SMBv1 enabled?
 - a. SMBv1 is the old Windows filesharing protocol. Modern windows doesn't use this; it wants v2 or v3.
 - b. Get-SmbServerConfiguration**
 - c. SMBv1 is disabled, SMBv2 is enabled.**
2. What SMB versions are supported?
 - a. SMBv1, SMBv2, SMBv3
3. What is SMB signing?
 - a. It is like a seal for SMB. It prevents tampering and man in the middle attacks.
4. Is SMB signing enabled/required in your relevant configuration?
 - a. Yes! EnableSecuritySignature = True. RequireSecuritySignature = True as well.**

SMB signing provides integrity/authentication protections for SMB communication; Microsoft documents that Windows environments can require signing for inbound connections, outbound connections, both, or neither.

How should SMB be securely configured?

Remediation Challenge

Pick one or two actual weaknesses. Before changing:

Weakness 1: Minimum Password length is only 7.

Why it's a risk: This can be easy for attackers to guess passwords with brute-force attacks or dictionary attacks.

Proposed change: New minimum password length is 12.

What might this break? It doesn't have the potential to break anything; we will just require a password reset for Employees who violate this new condition.

Why did I choose Active Directory as the first major project?

I wanted to learn how an enterprise actually works before going to attack one. I could have went from Kali -> Nmap -> scan a box -> copy an exploit -> get a shell. But I would have been attacking systems whose underlying design I barely understood. I started off by building the thing attackers and defenders actually interact with.

The big idea: identity is central to enterprise security.

Who are you? Authentication

What are you allowed to do? Authorization

Which computer belongs to the organization? Computer identity.

Who is an administrator? Privileged identity

Who gets Finance access? Group membership

How should workstations behave? Group Policy

Who created an account? Audit trail

Who added somebody to a privileged group? Identity-change telemetry

How do we reduce unnecessary privileges? Hardening